

AARON MARTINEZ
RISK MANAGEMENT FRAMEWORK

NPS PR & MARKETING CASE STUDY: FRAAP ASSESSMENT

FRAAP – OVERVIEW

- ▶ Risk assessment conducted in a short timeframe
- ▶ Structured & streamlined approach
- ▶ Accelerated assessment
- ▶ Cuts down the time to gather risk data and produce recommendations
- ▶ Good for one-time assessments

FRAAP – ASSESSMENT SESSION – GOALS

- ▶ Identification of risks and concerns
- ▶ Identification of threats
- ▶ Recommendations for controls to mitigate threats

FRAAP – ASSESSMENT SESSION – PRIORITIZE RISKS

- ▶ Analyze severity of each identified risk
- ▶ Rate based on likelihood of occurrence
- ▶ Prioritize based on rating and focus the rest of session on high exposure items
- ▶ Capture assessment and analysis in worksheets

FRAAP – WORKSHEETS – RISK DESCRIPTION LIST

- ▶ Identify concerns or risks
- ▶ Assign a risk type (CIA)
- ▶ Identify resource affected

FRAAP – WORKSHEETS – RISK DESCRIPTION LIST

Risk Type	Risk description	Resource
Availability	Antivirus software is not automatically updated for all systems, leaving the potential for viruses to infect servers and/or workstations	Servers & Workstations
Confidentiality	All users have Administrator privileges, allowing access to files and resources they may not need access to.	Network & Data
Confidentiality	Computers do not use file or disk encryption, so information may be disclosed or lost if a machine is compromised.	Network & Data
Confidentiality	Employees access the network remotely using username and password. This allows an attacker to access the network if credentials are compromised.	Network & Data
Confidentiality	Some employees use GoToMyPC for remote access. Vulnerabilities in the third party tool may expose the system to breaches.	Network & Data
Confidentiality	60% of employees do not lock files for secure access. Internal staff may have access to unauthorized resources such as payroll data.	Network & Data
Confidentiality	Vendors are allowed access to the company website and computers without authorization or supervision.	Network & Data
Availability	Part-time IT support may cause long wait times and employee frustration when resources are unavailable.	Servers & Workstations
Confidentiality	A generic default password is used for new accounts. Multiple people knowing the default credentials presents an opportunity for data compromise if the default is left unchanged.	Network & Data
Confidentiality	Users are not forced to change passwords when performing a reset and passwords do not expire. Reused and old passwords increase the chances that a previously compromised password will be used.	Network & Data
Confidentiality	Passwords do not have length or strength requirements. Short and weak passwords can be easily cracked by attackers.	Network & Data

FRAAP – WORKSHEETS – RESOURCE SENSITIVITY PROFILE

- ▶ Short description of asset sensitivity or importance
- ▶ Rate CIA sensitivities using Low-Moderate-High scale
- ▶ Determine overall sensitivity based on highest CIA values

FRAAP – WORKSHEETS – RESOURCE SENSITIVITY PROFILE

Resource Impacted	Sensitivity Description	Confidentiality	Integrity	Availability	Overall
Customer Data	Customer data breach is a violation of client privacy and may be used by competitive organizations.	High	Moderate	Moderate	High
Intellectual Property	Loss of intellectual property may damage the company reputation and enable competitive organizations.	High	Moderate	Moderate	High
Servers	Server compromise could lead to loss of data or disruption of operations.	High	High	High	High
Network	Network compromise could lead to loss of data or disruption of operations.	High	High	High	High
Private Employee Data	Employee information should not be accessible by other employees or outside parties without authorization.	High	Moderate	Low	Moderate
Workstations	Workstation compromise could lead to loss of data or disruption of operations.	Moderate	Moderate	Low	Moderate

FRAAP – WORKSHEETS – RISK EXPOSURE RATING

- ▶ Break each risk into threat/vulnerability pairs
- ▶ Rank final exposure value (derived from qualitative mapping table)

Vulnerability Description	STRIDE Category	Threat Activity	Severity	Likelihood	Sensitivity	Risk Exposure
Breach of unencrypted data	Information Disclosure	Physical theft of devices storing unencrypted confidential information.	High	High	High	High
Breach of unencrypted data	Information Disclosure	Cyber attack on devices storing unencrypted confidential information.	High	Moderate	High	High
Unauthorized remote access	Information Disclosure	Compromised credentials used to access network (password discovery, password cracking).	High	Moderate	High	High
Unauthorized access	Information Disclosure	Default passwords may be cracked or discovered by an attacker (shoulder-surfing, phishing) to gain access to resources.	High	Moderate	High	High
Unauthorized access	Information Disclosure	Reused passwords may be left at default values, cracked or discovered by an attacker (shoulder-surfing, phishing, guessing) to gain access to resources.	High	Moderate	High	High
Unauthorized access	Information Disclosure	Short and weak passwords may be cracked or discovered by an attacker (shoulder-surfing, phishing, guessing) to gain access to resources.	High	Moderate	High	High
Misuse of administrator privileges	Information Disclosure	Insiders may gain access to unauthorized files or resources.	Moderate	High	Moderate	Moderate
Unauthorized internal access	Information Disclosure	Employees may access unlocked files from other users and departments without authorization.	Low	High	Moderate	Moderate
Loss of access to IT resources	Denial of Service	Staff may lose access to resources when part-time IT support is unavailable.	Low	High	Moderate	Moderate
Virus or malware infection	Denial of Service	Virus or malware consumes system resources or blocks access to files through ransomware.	Moderate	Moderate	Moderate	Moderate
Unauthorized remote access	Information Disclosure	Third party GoToMyPC vulnerabilities may be exploited to gain access to company systems.	High	Low	High	Moderate
Unauthorized internal access	Information Disclosure	Vendors may access unlocked files and resources without authorization.	Moderate	Low	High	Moderate

FRAAP – WORKSHEETS – RISK EXPOSURE RATING

- Qualitative mapping table used to derive risk exposure

Severity	Likelihood	Risk Sensitivity		
		Low	Moderate	High
Low	Low	Low	Low	Low
Low	Moderate	Low	Low	Low
Moderate	Low	Low	Low	Moderate
Low	High	Low	Moderate	Moderate
Moderate	Moderate	Moderate	Moderate	Moderate
High	Low	Moderate	Moderate	Moderate
Moderate	High	Moderate	Moderate	High
High	Moderate	Moderate	High	High
High	High	Moderate	High	High

FRAAP – WORKSHEETS – MITIGATING CONTROLS LIST

- ▶ Identify mitigating controls
- ▶ Industry resources: ISO, NIST, NSA, US CERT, DoD
- ▶ Control types: preventative, detective, responsive
- ▶ Guidelines:
 - Identify controls that address multiple risks
 - Focus on cost-effective solutions
 - Total cost of control should be proportional to asset value

FRAAP – WORKSHEETS – MITIGATING CONTROLS LIST

Vulnerability Description	Threat Activity	Control Type	Control Description
Breach of unencrypted data	Physical theft of devices storing unencrypted confidential information.	Preventative	Enable full disk encryption (Microsoft Bitlocker, macOS FileVault).
Breach of unencrypted data	Cyber attack on devices storing unencrypted confidential information.	Preventative	Encrypt sensitive fields in databases.
Unauthorized remote access	Compromised credentials used to access network (password discovery, password cracking).	Preventative	Use two-factor authentication with cryptographic hardware tokens for authentication.
Unauthorized access	Default passwords may be cracked or discovered by an attacker (shoulder-surfing, phishing) to gain access to resources.	Preventative	Use randomly generated default passwords.
Unauthorized access	Reused passwords may be left at default values, cracked or discovered by an attacker (shoulder-surfing, phishing, guessing) to gain access to resources.	Preventative	Disallow password reuse.
Unauthorized access	Short and weak passwords may be cracked or discovered by an attacker (shoulder-surfing, phishing, guessing) to gain access to resources.	Preventative	Enforce strong passwords.
Misuse of administrator privileges	Insiders may gain access to unauthorized files or resources.	Preventative	Limit user privileges to the minimum required for job tasks.
Unauthorized internal access	Employees may access unlocked files from other users and departments without authorization.	Preventative	Enable file and folder permissions set by system administrator.
Loss of access to IT resources	Staff may lose access to resources when part-time IT support is unavailable.	Preventative	Transition to dedicated full-time IT support staff.
Virus or malware infection	Virus or malware consumes system resources or blocks access to files through ransomware.	Preventative	Implement automatic site-wide updates for antivirus software, managed by system administrator.
Unauthorized remote access	Third party GoToMyPC vulnerabilities may be exploited to gain access to company systems.	Preventative	Perform third-party vendor vulnerability assessment. Consider alternative solutions (Remote Desktop, VNC).
Unauthorized internal access	Vendors may access unlocked files and resources without authorization.	Preventative	Limit vendor access to computers and resources.
Unauthorized internal access	Vendors may access unlocked files and resources without authorization.	Preventative	Supervise vendors and other guests on premises.

FRAAP – CONCLUSION

- ▶ Technique for one-time time sensitive risk assessments
- ▶ Worksheets for capturing, rating, and mitigating risks
- ▶ Flexible enough for expanding over time or incorporating with another risk model

QUESTIONS?

REFERENCES:

- ▶ Kohnfelder, L., & Garg, P. (1999, April 1). The threats to our products. Retrieved from <https://adam.shostack.org/microsoft/The-Threats-To-Our-Products.docx>
- ▶ Wheeler, E. (2011). Security Risk Management: Building an Information Security Risk Management Program from the Ground Up. Waltham, MA: Elsevier.